23 April 2026

WEB APPLICATION VULNERABILITY ASSESSMENT REPORT

Target Website:
http://demo.testfire.net

Tools Used:
Nmap
OWASP ZAP

Prepared By:
DiyaMol Sabu

TABLE OF CONTENTS

1. Scope Of Testing ..... Page 3
2. Tools Used ..... Page 4
3. Network Scan Result ..... Page 5
3. Vulnerability Summary ..... Page 6
4. Cross Site Scripting (XSS) ..... Page 7
5. XSS Evidence ..... Page 8
6. SQL Injection ..... Page 9
7. SQL Injection Evidence ..... Page 10
8. Recommendations & Conclusion ..... Page 11

SCOPE OF TESTING

Target Website:
http://demo.testfire.net

Scope:
Web application security testing

Testing Type:
Black Box Testing

Objectives:
• Identify vulnerabilities
• Evaluate security posture
• Recommend fixes

Tools Used

Nmap

Used for:

- Port scanning
- Service detection

Command:

nmap -p 80,443 -sV demo.testfire.net

OWASP ZAP

Used for:

- Web vulnerability scanning
- Detecting XSS
- Detecting SQL Injection

NETWORK SCAN RESULTS (NMAP)

Port	State	Service	Version
80	Open	HTTP	Apache Tomcat
443	Open	HTTPS	Apache Tomcat

```
zsh: corrupt history file /home/kali/.zsh_history
┌──(kali㉿kali)-[~]
└─$ nmap -p 80,443 -sV demo.testfire.net
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-23 08:59 +0530
Nmap scan report for demo.testfire.net (65.61.137.117)
Host is up (0.097s latency).

PORT    STATE SERVICE  VERSION
80/tcp  open  http     Apache Tomcat/Coyote JSP engine 1.1
443/tcp open  ssl/http Apache Tomcat/Coyote JSP engine 1.1

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 20.38 seconds
```

Nmap output screenshot

VULNERABILITY SUMMARY

Vulnerability	Risk
Cross Site Scripting	High
SQL Injection	High
Missing Security Headers	Medium
Cookie Without SameSite	Low

Cross Site Scripting (XSS)Vulnerability

Risk Level: High

What is the issue?

The website allows user input to be displayed without proper security checks.
This means an attacker could insert malicious scripts into the website.

What could happen?

- Attackers could steal user login sessions
- Fake content could be shown
- Users could be redirected to harmful websites

Affected Area:

http://demo.testfire.net/sendFeedback

Recommended Fix:

- Validate all user input
- Encode output before displaying
- Use secure security headers

XSS Evidence Screenshot

http://demo.testfire.net (2)

Cross Site Scripting (Reflected) (1)

▾ POST http://demo.testfire.net/sendFeedback

Parameter	name
Attack	<scrIpt>alert(1);</scRipt>
Evidence	<scrIpt>alert(1);</scRipt>

Figure 1: Cross Site Scripting vulnerability detected in feedback form.

SQL Injection

Risk Level: HIGH

What is the issue?

The login form accepts user input that is not properly checked. This allows attackers to manipulate database queries.

What could happen?

- Attackers may bypass login
- Sensitive data could be accessed
- Database records could be changed or deleted

Affected Area:

http://demo.testfire.net/doLogin

Recommended Fix:

- Use prepared SQL statements
- Validate user input
- Avoid dynamic SQL queries

SQL Injection Evidence Screenshot

SQL Injection (1)

▾ POST http://demo.testfire.net/doLogin

Parameter	uid
Attack	ZAP' OR '1'='1' --

Figure 2: SQL Injection vulnerability detected in login form.

Security Recommendations

To improve the security of the website, the following actions are recommended:

- Validate all user inputs
- Use secure coding practices
- Enable security headers
- Perform regular security testing
- Use a Web Application Firewall (WAF)

Conclusion:

This assessment identified critical vulnerabilities that could allow unauthorized access or data exposure.

Immediate action is recommended to secure the application.